Sequence Diagram - Toàn Diện Xác Thực Auth (Register, Login & JwtAuthGuard)

Please use CSS style instead of skinparam ParticipantPadding

Frontend (Next.js)

Backend (NestJS)

Khách hàng (User)

Page / Component (app/auth/..., app/checkout/...)

Zustand: useAuthStore (store/useAuthStore.ts)

Client: API Service (services/auth.service.ts, order.service.ts)

Guard: JwtAuthGuard (modules/auth/guards/jwt-auth.guard.ts)

Strategy: JwtStrategy (modules/auth/strategies/jwt.strategy.ts)

Controller: AuthController / OrdersController (modules/auth/..., modules/orders/...)

Service: AuthService / OrdersService (modules/auth/..., modules/orders/...)

Security: bcrypt & JwtService (@nestjs/jwt, bcrypt)

Database: PrismaService (prisma/prisma.service.ts)

Luồng 1: Đăng Ký Tài Khoản (Register)

1 Nhập email, password, fullName & nhấn "Đăng ký"

2 registerApi({ email, password, fullName })

3 POST /api/v1/auth/register (RegisterDto)

4 register(dto)

5 prisma.user.findUnique({ where: { email } })

6 Kết quả tìm kiếm

alt [Email đã được sử dụng]

7 throw ConflictException('Email này đã được sử dụng')

8 409 Conflict: { success: false, message: "Email này đã được sử dụng" }

9 Ném ApiError(409)

10 Hiển thị banner lỗi "Email này đã được sử dụng"

[Email chưa tồn tại (Hợp lệ)]

11 bcrypt.hash(dto.password, 10)

12 passwordHash (saltRounds = 10)

13 prisma.user.create({ data: { email, passwordHash, fullName, loyaltyPoints: 0 } })

14 user record (id, email, fullName, loyaltyPoints)

15 jwtService.signAsync({ sub: user.id, email: user.email })

16 accessToken

17 { accessToken, user: { id, email, fullName, loyaltyPoints } }

18 201 Created: { success: true, statusCode: 201, data: { accessToken, user } }

19 AuthResponse

20 login(res.accessToken, res.user)

21 localStorage.setItem('token', token)

22 State updated

23 router.replace(next || '/menu')

Luồng 2: Đăng Nhập (Login)

24 Nhập email, password & nhấn "Đăng nhập"

25 loginApi({ email, password })

26 POST /api/v1/auth/login (LoginDto)

27 login(dto)

28 prisma.user.findUnique({ where: { email } })

29 Kết quả tìm kiếm user

alt [Không tìm thấy user với email cung cấp]

30 throw UnauthorizedException('Email hoặc mật khẩu không chính xác')

31 401 Unauthorized: { success: false, message: "Email hoặc mật khẩu không chính xác" }

32 Ném ApiError(401)

33 Hiển thị banner lỗi "Email hoặc mật khẩu không chính xác"

[Tìm thấy user]

34 bcrypt.compare(dto.password, user.passwordHash)

35 isValid (boolean)

alt [Mật khẩu không trùng khớp (isValid === false)]

36 throw UnauthorizedException('Email hoặc mật khẩu không chính xác')

37 401 Unauthorized: { success: false, message: "Email hoặc mật khẩu không chính xác" }

38 Ném ApiError(401)

39 Hiển thị banner lỗi "Email hoặc mật khẩu không chính xác"

[Mật khẩu hợp lệ (isValid === true)]

40 jwtService.signAsync({ sub: user.id, email: user.email })

41 accessToken

42 { accessToken, user: { id, email, fullName, loyaltyPoints } }

43 200 OK: { success: true, statusCode: 200, data: { accessToken, user } }

44 AuthResponse

45 login(res.accessToken, res.user)

46 localStorage.setItem('token', token)

47 State updated

48 router.replace(next || '/menu')

Luồng 3: Xác Thực JWT Qua JwtAuthGuard Bảo Vệ Tuyến API (Protected Routes)

49 Thao tác yêu cầu xác thực (ví dụ: Nhấn "Xác nhận đặt hàng")

50 createOrder(dto)

51 POST /api/v1/orders
Headers: Authorization: Bearer <accessToken>

52 ExtractJwt & Passport verification
(Kiểm tra JWT_SECRET & hạn dùng JWT_EXPIRATION)

alt [Token không tồn tại, hết hạn hoặc sai chữ ký]

53 Verification failure

54 Chặn request, ném UnauthorizedException

55 401 Unauthorized: { success: false, statusCode: 401, message: "Vui lòng đăng nhập để tiếp tục", path: "/api/v1/orders" }

56 Ném ApiError(401)

57 Chuyển hướng về trang đăng nhập (/auth/login?next=/checkout)

[Token hợp lệ]

58 validate(payload: JwtPayload)
Kiểm tra { sub, email }

59 return { sub: payload.sub, email: payload.email }

60 Gắn req.user = { sub: userId, email }
Chuyển tiếp request vào OrdersController.create()

61 create(req.user.sub, dto)

62 Thực thi nghiệp vụ tạo đơn hàng gắn với userId

63 newOrder record (#1042)

64 newOrder

65 201 Created: { success: true, statusCode: 201, data: newOrder }

66 OrderDetail

67 Điều hướng sang trang Thanh toán (/checkout/payment?orderId=...)